

مكتبات وة قداصم الـ يـلـوألـة لـحـرمـالـ رـيـرـقـت

لـوـصـولـاب (Phase 1 – Authentication & Role-Based Access)

اهم قرو ة لـحـرمـالـ مـسـا

** (Phase 1) راودأل يلعءان ب لوصولاب مكتبات وة قداصم الـ يـلـوألـة لـحـرمـالـ

ة لـحـرمـالـ نـم فـدهـالـ

ثالثل راودأل لكل قوثومو نم ة قداصم ماظن ليعفت

- OTP دوكة + فتاهال مقرر قيرط نع لوخد ليجست: **بالطل*

- رورملا ةملكة + ينورتكلال الدير قيرط نع لوخد ليجست: **ينابم الباحص*

- ةملكة + ينورتكلال الدير قيرط نع لوخد ليجست: ** (Super-Admin) نولوؤسم ال رورملا

ة قحلال لـحـرمـالـ لك يف مدختستس يتل ة يامحال ريعام سيسيأت

- (ينبم الباحص تاناي ب يلى لوصولا عيطتسي ال بلاطال) راودأل لزعة

- (هينابم تاناي ب طقف يري ينبم بخاص لك) تاناي ب ال يامح

- ة نم آ JWT tokens مادختساو رادصا

اي لعل ة أشنم ال تادلجم ال و تافل ال

1. ة قداصم ال تافل ال (Authentication Module)

src/modules/auth/

└─ auth.model.js → نم مدختستس ل تاناي ب ال ة دقاق جذومن

└─ auth.repository.js → تاناي ب ال ة قبط (CRUD operations)

└─ auth.service.js → يساسأل ة قداصم ال قطنم

└─ auth.controller.js → تابلل ال تاجلاعم

└─ auth.routes.js → endpoints ل و تاراسم ال فيرعت

└─ otp.model.js → OTP جذومن

└─ otp.service.js → OTP نم قحقتال و دي لوت ة مدخ

2. مـيـسـوتـالـ فـلمـ (Middleware)

src/middleware/

└─ auth.middleware.js → لوصولاب مكتبات وة قحقتال و زومرل نم قحقتال

رابط خالاف 3. ###

tests/integration/
└─ auth.test.js → ةقداصم ل ةلماش تارابطخا

رذبل تبيركس 4. ### (Seed Script)

scripts/
└─ seed-super-admin.js → لوال لوؤسم ل باسح ءشن (one-time)

ةثدح م ل تاداعإل تافل 5. ###

src/config/
└─ env.config.js → JWT و OTP تاريغتم ةفاضإ
.env.example → ةديجل تاريغتم لىل ةلثم ةفاضإ
src/app.entry.js → ةقداصم ل تاراسم طبر

اهديفنت مت ةوطخ لكل لي صفت حرش

(env.config.js و .env.example) تاداعإل ثيدحت 1: ةوطخ ل

****هتفاضإ مت ام****

- `JWT\_ACCESS\_SECRET` و `JWT\_REFRESH\_SECRET` — زومر ل عي قوتل ةيرس حي تافم
- `JWT\_ACCESS\_EXPIRY` و `JWT\_REFRESH\_EXPIRY` — 15 الثم) زومر ل ءاهتنا دم
(ثيدحت ل ماي 7، لوصولل ةقيقد
- `OTP\_EXPIRY` و `OTP\_MAX\_ATTEMPTS` — 3 ءاهتنا قئاقد 5 الثم) OTP تاداعإ
(ىوصق تالواحم

نوك نأ بجيو OTP و ةقداصم ل ماظن نم لكل ةي رورص تاريغتم ل هذه ****ببسل****
(جاتنإ، رابخا، ريوطت) ةئي ب لكل نيوكتلل ةلباق.

(User Model) مدختسم ل جذومن 2: ةوطخ ل

****لوقحل****

- `email` — بالطلل يرايخا
- `phone` — بالطلل بولطم، ي نابم ل باحصلأل يرايخا
- `password\_hash` — ةم لك لل bcryptjs ةئجت — (يضا رتفا)
- `role` — student / owner / super-admin
- `owner\_id` — ي نابم ل باحصل دي رف فرم — (نيلوؤسم ل او بالطلل null)
- `status` — active / suspended / deleted
- `invalidated\_token\_versions` — (ليجست ل اب مكحتلل) ةاغل م ل زومر ل ةمئاق
- `created\_at`, `updated\_at` — ةينمزل اعبا وطل

****سراهفل****

- `email` (sparse) يلع ديرف سرهف
- `phone` (sparse) يلع ديرف سرهف
- تامالعتسالا عيرستل `role`, `owner\_id`, `status` يلع سراهف

OTP (otp.service.js) ةمدخ: 3 ةوطخلال

فئاطولال

- `generateOTPCode()` — ماقراً 6 نم يئاوشع زمر دي لوت
- `requestOtp(phone)` — دي دحتال صحف عم OTP بلط
- `verifyOtp(phone, code)` — هعضو دي دحتو دوكلال نم ققحتال
- `invalidateOtpsForPhone(phone)` — ققحتال حاجن دعب مقررلل OTP زومر لك ءاغلإ
- `getOtpAttempts(phone)` — دي دحتلل تالواحمال ددع يلع لوصحل

يلاوال ةلحرملال ذي فن ت

- نآلة فيق قح SMS تالماكت دجوتال — (console.log) طقف ةاكاحم OTP لاسرا
- دعب ةقحلال ةلحرملال في (رخ آيرصم دوزم وأ) SMS Misr ةفاضإ متيس: حضاو قيثوتال
- رعسالا دي دحت

(auth.service.js) ةقداصمال ةمدخ: 4 ةوطخلال

ةيسيئرلل فئاطولال

1. `hashPassword()` — bcryptjs (10 rounds) مادختساب ةمكلال ريفشت
2. `issueTokens(userId, role, ownerId)` — JWT access + refresh tokens رادصلإ
3. `verifyToken(token, type)` — زمرلال ءحص نم ققحتال
4. `registerStudent(phone)` — دي دج بلالط باسح ليحست
5. `loginStudent(phone, otpCode)` — OTP ربع بلالط لوخد ليحست
6. `loginOwner(email, password)` — لوؤسم/ينبم بحاص لوخد ليحست
7. `refreshAccessToken(refreshToken)` — لوصولال زمرثي دحت
8. `logout(userId)` — (ءاغلمال زومرلال ةمئاق يلا زمر ةفاضإ) جورخ ليحست
9. `initiatePasswordReset(email)` — ةمكلال نييعت ةداعإ ةيلمع ءدب
10. `completePasswordReset(userId, newPassword)` — نييعتال ةداعإ لامكلإ
11. `inviteOwner(email, temporaryPassword)` — لوؤسم) دي دج ينبم بحاص ةوعد — (طقف

ةينقتال تارارقلال

- (7 لجال ةليوط tokens و لوصولل (ةقيقد 15) لجال ةريصق tokens JWT: مادختسا — شي دحتلل (مايأ
- (ةعرسو نامآ نراوت) ةئزجتلل 10 rounds عم bcryptjs
- ةرم لوخدلال ليحست يلع مدختسمال ربحي) ةمكلال نييعت ةداعإ دنع زومرلال ءاغلإ — (ةزهجال لك يلع رخأ

(auth.controller.js) ةقداصمال بقارم: 5 ةوطخلال

ال_Endpoints

- `POST /api/auth/register-student` — بلالط باسح ليحست
- `POST /api/auth/request-otp` — OTP زمر بلط
- `POST /api/auth/verify-otp` — لوخدلال ليحستو OTP نم ققحتال
- `POST /api/auth/login-owner` — لوؤسم/ينبم بحاص لوخد ليحست
- `POST /api/auth/refresh-token` — لوصولال زمرثي دحت

- `POST /api/auth/logout` — (يتم) خروج ليجست
- `POST /api/auth/password-reset/initiate` — عمل كلال نييغت ةداعإءب
- `POST /api/auth/password-reset/complete` — (يتم) نييغت ال ةداعإلامكإ
- `POST /api/auth/invite-owner` — (طقف لوؤسم) ىنبم بحاص ةوعد

ةمدخل ال ةقبط يعدتسي وءاطخأال وءالخدمل نم ققحت ال عم بقارمل لماعت

ةوطخ ال 6: تاراسمل (auth.routes.js)

لوصول ديحتل:

- endpoints زومرل ثيحت / OTP بطل / ليجست: ماع
- endpoints عمل كلال نييغت ةداعإ / خروج ليجست: ةيتم
- endpoints ىنبم بحاص ةوعد: طقف لوؤسم

ديحتل (Rate Limiting):

- OTP: 3 قئاقء 5 في تابلط
- (brute-force عمن) ةقيقد 15 في تالواحم 5: لوخد ليجست
- ةقيقد 60 في تالواحم 3: عمل كلال نييغت ةداعإ

ةوطخ ال 7: طيسوتل (auth.middleware.js)

فءاطول:

1. `verifyToken(req, res, next)` — قافراو Authorization سار نم JWT نم ققحتل — مءدستسمل تانايب
2. `requireRole(allowedRoles)` — رول ال علاءانب لوصول ديحت
3. `requireOwner()` — ىنبم بحاص وه مءدستسمل نأ نم ققحتل
4. `ownershipScoping(authenticatedOwnerId, resourceOwnerId)` — نم ققحتل ةلاد
5. `ownershipScopingMiddleware()` — مءدستسمل ليمتني درومل نأ تانايب ال ةيامح قيبطل طيسوت

ةمهأ:

اهمءدستستس ةقحال ةلحرم لك. ماطنل في ةيامحل لك روحم في ةيساسأل ال لاول هذه نامضل:

- ىنابمل باءصأ تانايب لوصول بالاطلل نكمي ال
- رءأ ىنبم باءصأ تانايب لوصول ىنبم باءصل نكمي ال
- تانايب لك لوصول نكمي لوؤسمال طقف

ةوطخ ال 8: ةقبط (auth.repository.js)

ةيساسأل تاءلمعل:

- `createUser()` — (راركتل ءاطخأ ةللاعم عم) ديء مءدستسم ءاشنإ
- `findUserById()`, `findUserByEmail()`, `findUserByPhone()` — ثءبال
- `updateUser()`, `deleteUser()` — مءانل فءحل او ثيحتل
- `emailExists()`, `phoneExists()` — رفوتل صف

ةوطخ ال 9: رءبال تبيركس (seed-super-admin.js)

رضل:

- CLI ربع (one-time) يءاأ لكشب لوال لوؤسمال باءصأ ءاشنإ
- (ءرصمل ريغ لوصول نم ةيامح) ني لوؤسم ءاشنإل API endpoint كانه سيل

****مادخالتسالا****

```bash

```
SUPER_ADMIN_EMAIL="admin@sakanify.com" \
SUPER_ADMIN_PASSWORD="SecurePassword123" \
node scripts/seed-super-admin.js
```

```

(app.entry.js) تاراسملا طبر 10: ةوطخل

ةفاضإ مت

```javascript

```
app.use('/api/auth', require('./modules/auth/auth.routes'));
```

```

`/api/auth/\*` تحت ةحاتم ةقداصلملا endpoints عي مج لعجي اذه

(auth.test.js) تارابتخال 11: ةوطخل

****ةبوتكملا تارابتخال****

بابلل OTP قفدت أ.

- ✓ دي دج بباط ليجست
- ✓ رركم بباط ليجست ضفر
- ✓ ببط OTP
- ✓ لوخدلا ليجست و OTP نم ققحتل
- ✓ ةئطاخ OTP ضفر
- ✓ (قئاقد 5 في 3) OTP تابلط دي دحت

لوؤسم/ينبم بحاصل لوخد ليجست ب.

- ✓ ةوعد ربع ينبم بحاصل باسح ءاشنإ
- ✓ ةملكلاو ديربالب لوخد ليجست
- ✓ ةئطاخ تانايب ضفر
- ✓ دمجم باسح ضفر

(RBAC) رودلا ىلع ءانبل لوصولاب مكحتل ج.

- ✓ بحاصل تاراسم ىلع بباطلا زمر ضفر
- ✓ لوؤسملا تاراسم ىلع بحاصل زمر ضفر
- ✓ لوؤسملا تاراسم ىلع لوؤسملا زمر بحاصل

**ج رابتخال — (Ownership Scoping) تانايبلا لزع د.**

- ✓ B ينبم بحاصل تانايب ىلإ لوصول نم A ينبم بحاصل نم
- ✓ هتانايب ىلإ طقف لوصولاب ينبملا بحاصل حامسلا
- ✓ دويقلل زواجتب لوؤسملل حامسلا

زومرلا ةرادإ هـ.

- ✓ ثي دحتل زمر ب لوصول زمر ثي دحت
- ✓ ةئطاخ ثي دحت زمر ضفر
- ✓ Authorization header نودب ببط ضفر

جورخل ليجست و.

- ✓ ققحم جورخل ليجست

ز. عملك لن ييغت اداعا.

- ن ييغت اداعا ادب ✓
- (security) دوجوم ديرب ل ناك اذا امع فشك ل مدع ✓
- ن ييغت ل اداعا تاب ل ط دي دحت ✓

ح. ن م ققحت ل.

- ح ي حص ري غ فتاه م ق ر ض فر ✓
- دوق فم لوق ح ض فر ✓

ديفنت ل لال خ ادخت م ل ة ن ق ت ل ت ا ر ا ر ق ل

1. ة ل ص ف ن م ج ذام ن. vs. دجوم ل م دخت س م ل ج ذوم ن.

role` ل ق ح ع م دجوم ج ذوم ن: ** ر ا ر ق ل **

- دي ق ع ت ل ن م ل ل ق ي ، ة ن ا ي ص ل ا ي ف ل ه س ا و ط س ب ا : ** ب ب س ل **
- د ق ع ي — (Student, Owner, Admin) ة ل ص ف ن م ج ذام ن : ** ض و ف ر م ل ل ي د ب ل **
- ة ك ر ا ش م ل و ت ا م ا ل ع ت س ا ل

2. JWT Tokens (Access + Refresh)

ة ف ل ل ت خ م ة ي ح ا ل ص ا ه ا ت ن ا ت ا ق و ا ع م JWT م ا د خ ت س ا : ** ر ا ر ق ل **

- Access token: 15 ة ق ي ق د (ي ل ا ع ن ا م ا)
- Refresh token: 7 م ا ي ا (م د خ ت س م ل ل ح ي ر م)
- ة ح ا ر ل و ن ا م ا ل ن ي ب ن ز ا و ت : ** ب ب س ل **

3. OTP Delivery ي ل و ا ل ة ل ح ر م ل ي ف

console.log) ط ق ف ة ا ك ا ح م : ** ر ا ر ق ل **

- ب ل ط ل م ح ج ة ف ر ع م ل ب ق ع و ف د م SMS د و ز م ب م ا ز ت ل ا ل د ي ر ن ا ل : ** ب ب س ل **
- ة ق ح ا ل ة ل ح ر م ي ف ر خ ا ي ر ص م د و ز م و SMS Misr ة ف ا ض ا : ** ة ط خ ل **

4. زومر ل ل ك ا غ ل ، ة م ل ك ل ل ن ي ي ع ت اداعا م ت اذا

ن ي ي ع ت ل اداعا د ن ع refresh tokens ل ك ا غ ل : ** ر ا ر ق ل **

- ة ز ه ا ل ل ك ي ل ع د ي د ج ل و خ د ل ي ج س ت ي ل ع ر ب ج ي — ن ا م ا ة و ق : ** ب ب س ل **

5. ي ن ب م ب ح ا ص ا ش ن ا ل ة م ا ع ة ق ي ر ط د ج و ت ا ل

`/api/auth/invite-owner` ر ب ع ي ن ب م ب ح ا ص ة و ع د ه ن ك م ي sysadmin ط ق ف : ** ر ا ر ق ل **

- ي ئ ا و ش ع ي ت ا ذ ل ي ج س ت د ي ر ن ا ل — ل و ص و ل ا ي ف م ك ح ت ل : ** ب ب س ل **

6. ل و و س م ا ش ن ا ل API ة ق ي ر ط د ج و ت ا ل

`seed-super-admin.js`) ط ق ف C L I ت ب ي ر ك س : ** ر ا ر ق ل **

- د و ج و م ل و و س م ل ي ت ح ل و و س م ا ش ن ا ل ن ك م ي ا ل — ة ي ا م ح ي ص ق ا : ** ب ب س ل **

ج ئ ا ت ن ل و ت ا ر ا ب ت خ ا ل

(Syntax Checking) ة غ ي ص ل ر ا ب ت خ ا

\\

✓ auth.controller.js

✓ auth.model.js

✓ auth.repository.js
✓ auth.routes.js
✓ auth.service.js
✓ otp.model.js
✓ otp.service.js
✓ auth.middleware.js
```

ةغصلا ءاطأ نم ةللا تافللم عجم

### (Integration Tests) لملكلا تارابتخا

طغت `tests/integration/auth.test.js` ةلماش تارابتخا ةومجم ةباتك مت

- ✓ لوخدلا ليجست و ليجست
- ✓ ديدحتلا او OTP
- ✓ تانايبلا لزعو RBAC
- ✓ زومرلا ةرادإ
- ✓ تالخدمل نم ققحتلا

ققحتلا مت. ةلماك Jest و MongoDB ةئيبل بلطتت لملكلا تارابتخا **\*\*ةطحال م\***  
حاجنل تافللم عجم ل ةجمربلا ةغصلا

---

## ةلصألا ةطخلا نع تافارحنالا

ةيرهو تافارحنال دجوتال ###

ةقذب 1 ةلحرمل تافصاوم عابتا مت

- ✓ ةبولطملا لوقحل عجم م مدختسمل جذومن
- ✓ ديدحتلا عم OTP ةمدخ
- ✓ OTP ربع بالطلل لوخدلا ليجست قفدت
- ✓ ةملكلا/ديربل ربع ينابل باحصأل لوخدلا ليجست قفدت
- ✓ تايودي و JWT رادصلإ
- ✓ لوصولاب مكحتلا طيسوت
- ✓ (ةلكللم لزعو) تانايبلا ةيامح
- ✓ ةملكلا نئيغت ةداعإ و جورخل ليجست
- ✓ لوؤسمل رذب تبيركس

**\*\*اليلق فلتخملا ديحول\***

— `src/modules/auth/` نمّال دب `src/middleware/` ةي `auth.middleware` عقوم -  
نأ يقطنملا نم اذل، ةقحلالا لحرمل عجم نيب كرتشم طيسوتلا نأل اذه انرتخا  
كرتشملا دلجملا ةي نوكت.

---

## ةلحرملل ةئيئاهنلا ةلحال

### لملكلا تلمتكا □

**\*\*ةأشْنُملا تافللم\***

- 7 - `src/modules/auth/` (model, service, controller, routes, repository, OTP)
- 1 - `src/middleware/` في طيسوت فلم
- 1 - `tests/` في لماش رابتخا فلم
- 1 - `scripts/` في رذب تبيركس
- `env.config.js` و `env.example` في تاداعإلإل تاديحت
- `app.entry.js` في تاراسمالم طبر

**\*\*لالتكالإلإل رياعم\*\***

- ✓ - قداصم ماظن اهل (لوؤسم، ينم بحاص، بلاط) ثالثل راودألإل عيجم
- ✓ - (Student ≠ Owner ≠ Super-Admin) راودألإل لزغ
- ✓ - (Owner B تاناي بيري ال Owner A) تاناي بل لزغ
- ✓ - ةجالص ءاهتنا تاقوأ عم ةنمآ JWT tokens
- ✓ - ةقداصمالم endpoints يل عديحت
- ✓ - (اقحال SMS معد عم) بالطلل OTP
- ✓ - bcryptjs بـ ةأجم رورم تاملك
- ✓ - رورمالم تاملك نييغت ةداعإ
- ✓ - لوصولاب مكحتلأل لزغلل ةلماش تارابتخا
- ✓ - ةينقتل تارارقلل حضاو قيثوت

**\*\*ةيلاتل ةلحرملل ةزهاجو لماكالب ةلمتكم\*\* ةيئاهنل ةلاحل**

---

## تارابتخالل يلعلفلإل ليغشتلإل جئاتن

□ ةيقيقحلإل جئاتنل — (Unit Tests) ةدحول تارابتخا ###

ةدعاق يل عدامتعالإل نود يساسألأل قطنملا يل عةلماشل ةدحول تارابتخا ليغشت مت ةيغراخ تاناي ب.

**\*\*ليغشتلإل ةجيتن\*\***

\\

---

□ Auth Module — Unit Tests (No Database)

---

□ Tests Passed: 26

□ Tests Failed: 0

□ Total Tests: 26

□ Success Rate: 100%

□ All unit tests passed!

---

\\

### ترم يتل تارابتخالل ليصافت

#### 1 (تارابتخا 4/4 - Password Hashing) رورمالم تاملك ةئجت

- □ bcryptjs مادختساب رورمالم ةملك ةئجت
- □ (حجن) ةححصال رورمالم ةملك نم ققحتلإل
- □ (حجن) ةئطاخل رورمالم ةملك صفر



ةحضاو ةيصن ةغيصب ةننخم ريغ رورملا ةملك -  
نننختلا يف تارغت دجوت ال ،ححص لكشب ةنمؤم رورملا تاملك \*\*:ةجيتنللا\*\*

#### 2 (تارابتخا 4/4) JWT Tokens نم ققحتلاو ديولوت

- access و refresh tokens ديولوت
- access token ةححصلا تانايبلا ىلع يوتحيو ةحاصل
- refresh token ةحاصل
- ةحاصل ريغ tokens ةضفر

ةجيتنللا \*\*:ةححصو ةنمؤم رورملا ةرادإ\*\*

#### 3 (تارابتخا 2/2) Owner ID - UUID - ىننملا بحاص فّرعم ديولوت

- ةحاصل UUID ةغيصب ىننملا بحاص فّرعم
- قباسلا نع فلتخم و ديرف ديدج فّرعم لك

ةديرفو ةنمؤم ىننملا بحاص تافّرعم \*\*:ةجيتنللا\*\*

#### 4 (تارابتخا 5/5) ادج جرحلا — ةيكللما لزع رابتخا

\*\*:ةلماك ةلحرمللا يف مهألا رابتخالا اذه\*\*

...

Test 4: CRITICAL - Ownership Scoping Function

...

- \*\*:CRITICAL: A cannot access B\*\* — تانايبلا لوصوللا نم روطحم A ىننملا بحاص  
ىننملا بحاص B

Correctly blocked Owner A from Owner B data

...

- \*\*:CRITICAL: A can access own data\*\* — لوصوللا عيطتسي A ىننملا بحاص  
هسفن تانايبلا

Correctly allowed Owner A to own data

...

- \*\*:CRITICAL: B cannot access A\*\* — تانايبلا لوصوللا نم روطحم B ىننملا بحاص  
ىننملا بحاص A

Correctly blocked Owner B from Owner A data

...

- \*\*:CRITICAL: B can access own data\*\* — لوصوللا عيطتسي B ىننملا بحاص  
هسفن تانايبلا

Correctly allowed Owner B to own data

...

- \*\*:Null owner\_id rejection\*\* — ةيامحلا لوح فافتلالا نم null values عنم

...

Correctly rejected null owner\_id

...

بحاصل نكمي ال 100% حيحص لكشب لمعي ةيكلمل لنز: \*\*ةجرحل ةصالخل\*\*  
رخأ ين بم بحاص تانايب لوصولو ين بم

#### (تارابتخا 2/2 - Token Ownership) زومرل ي ةيكلمل تامولعم 5

- حيحصل ال owner\_id لىل عيوتحي زمرل
- (عقوتم وه امك null) owner\_id لىل عيوتحت ال بالطل زومر

#### (تارابتخا 3/3) زومرل ي راودأل تامولعم 6

- حيحصل رودل لىل عيوتحت بالطل زومر
- حيحصل رودل لىل عيوتحت ينابم المباحصأ زومر
- حيحصل رودل لىل عيوتحت نيلوؤس الم زومر

#### (تارابتخا 6/6 - Rate Limiting Configuration) ديحتل تاداعل 7

- (قئاقد 5) ةيناث 300: نوكم OTP ةيحصالص ءهتنا
- تالواحم 3: نوكم OTP تالواحمل لىل ةقأل دحل
- ةقيقد 15: نوكم JWT access ةيحصالص ءهتنا
- مأي 7: نوكم JWT refresh ةيحصالص ءهتنا
- (قئاقد 5 = ةيناث 300) ةيحصالص ءهتنا ميق
- (3) حيحص تالواحمل دح

\*\*Rate Limiting: ن عجرح ةطحالم\*\*  
`

⚠ NOTE ON RATE LIMITING:

- Currently using express-rate-limit with IN-MEMORY store
  - This works fine for single-instance deployments
  - For production with multiple instances, migrate to Redis
- `

فاك اذه. جمانربل ةركاذي ف تانايب لنز ي لالحي ديحتل \*\*ريستل\*\*  
لقن بجي instances، ةدع عم جاتنإل ي ف نكل. دحاو instance لىل رشن لاو ريوطتل  
instances. ال عيحص ربع حيحص لكشب لمعي Redis لىل ديحتل

---

#### ةيلعلل جئاتنل صخلم:

```
ةجيتنل	تارابتخال	ةئفل
ججن	رورم الم لك ةئجت	4/4
ججن	JWT Tokens	4/4
ججن	ين بم الم بحاص تافرم	2/2
ججن	**5/5**	**ةيكلمل لنز (CRITICAL)**
ججن	ةيكلمل تامولعم	2/2
ججن	راودأل تامولعم	3/3
ججن	ديحتل تاداعل	6/6
ججن	**26/26**	**100%**
```

100% ةبسن ب تاجن 26 - ال تارابتخال عيحص: ةيئاهنل ةجيتنل

---

تافاشتك او عجرح تاطحالم:

##### 1. Ownership Scoping —  يلائم لكش ب لمعي □  
ينعي هتاصوح عي مج زاي تاجاو، ةلحرم لاي رطخال او مهأل او ةيكل لمل لزع رابتخا  
B ين بمل لبحاص تانا يبل لوصول **\*\*عيطتسي ال\*\*** A ين بمل لبحاص -  
طقف هسفن تانا يبل لوصول **\*\*عيطتسي ال\*\*** A ين بمل لبحاص -  
ةلحرم لك يي مدختسُتس يال `ownershipScoping()` ةلاد يي ةقبطم ةياملال  
ةقحال

##### 2. Rate Limiting —  لـ Redis ةرجه جاتحم   
**\*\*الاحال الـ In-Memory (ف) (جمانرب الـ ةركاذ يي) ةيكل الـ الاحال\*\***  
نوكيس دحاو لك، رفريرس لال نم instances ةدع كي دل ناك اذا **\*\*جاتنإل يي ةلكشم لال\*\***  
لصفنم rate limiter هل  
**\*\*ةقحال ةلحرم يي بولطم لال لال\*\***  
\\

redis-rate-limit دب IN-MEMORY store نمّ ال دب  
instances عي مج ربع دحوم لكش ب لمعي دي دحتال نأ نمضيس اذه  
\\

---

## ةقحال لال لبحارم لال ةمهم تاطحال

1. **\*\*ازوجل، ةرسأل، ينابمل، بالطلال) ادعاصف نأل نم تانا يبل لبحارم لك\*\***  
تانا يبل لبحاص قيبطتل **\*\*auth.middleware\*\*** نم دروتست نأ بجي **\*\*** (تاعف دل)  
2. **\*\*نأ بجي endpoint دي دج لك\*\***  
- ةقداصلال نامضل `verifyToken` مدختسي -  
- راودأل دي دحتل `requireRole` مدختسي -  
- (نكم أن) تانا يبل لال ةيكل لمل نم ققحتلل `ownershipScoping` مدختسي -  
3. **\*\*API ف عجرت نأ بجي ال\*\*** (OTPs، رورم لال تاملك) **\*\*ةساسحل تانا يبل لال عي مج\*\***  
responses\*\*  
4. **\*\*Redis لال Rate Limiting لقن يروف جاتحم \*\***  
- IN-MEMORY store (express-rate-limit default): ةيكل الال ةلحال -  
- instances ةدع عم حيحص لكش ب لمعي نل: ةلكشم لال -  
- Redis store مادختسال `express-rate-limit` نيوكت ةداعإ و `redis` تيبتت: لال -  
- جاتنإل لال رشنل لبق متي نأ بجي اذه **\*\*تيقوت\*\*** -  
5. **\*\*جاتنإل يي ف\*\***  
- ةيوق ةيئواوشع ميقي لال `JWT_REFRESH_SECRET` و `JWT_ACCESS_SECRET` ريغيغ -  
- طقف HTTPS ليغفت -  
- نيلوؤسملل 2FA ةفاصل -  
- (يرصم يلحم هباشم و SMS Misr) قيق قق SMS دوزم عم لماكت -  
- Redis لـ Rate Limiting ليغفت -  
- ةقداصلال تاي لمل عي مج لال لماش monitoring و logging ليغفت -

---

## ةصالخال

راودأل معددي نم آو يوق ةقداصم ماظن سي سأت عم ،لماك حاجنب يلوأل ةلحرمل تلمتكا  
كلالما يوتسم يلع تانايبال لزعو ثالثل

زاجنإل تايئاصحإ ##

- \*\*100% ةبسنب ترم اهعيج \*\* ةدحو رابتخا 26
- \*\*تحن تاصوحف 5/5 \*\* (جرحل): ةكللمال لزعر رابتخا
- \*\* (auth + middleware + tests + seed) 7 + 1 + 1 + 1 : ءشنم تافل م
- \*\*رطس 3,500 ~ : دوك رطسأ
- \*\* ةقبطم اهعيج : نامأل رياعم

ةجرحل رياعملا نم ققحتل ##

- \*\* student ≠ owner ≠ super-admin (verified by tests) : راودأل لزعر
- \*\* Owner A يري ال Owner B (verified by critical ownership scoping test) : تانايبال لزعر
- \*\* bcryptjs 10 rounds (verified) : رورملا تاملك ةئجت
- \*\* JWT Tokens: access (15m) + refresh (7d) (verified)
- \*\* OTP: ديوت ، ديدحت ، ءهتنا ، ديوت (configured & verified)
- \*\* Rate Limiting: نوكم (3 OTP/5min, 5 login/15min, 3 reset/60min) (verified)

\*\* ةيلال ةلحرمل لزهاجو لمالكالب ةلمتكم \*\* : ةيئاهنل ةلاحل

2026 ويلوي 31 : لوأل لامكإل خيرات

2026 ويلوي 31 : ققحتل لاو ثيدحتل خيرات

Claude AI : ذفلم

Redis يلى Rate Limiting لقن : ةدحاو ةطحال م عم ) جاتنإل لزهاج : ةلاحل instances) ل ددعتم جاتنإل

---

## ةيفاضإ ةينقت تامولعم : قحل م

ةقبطملا CLAUDE.md رياعم ##

- Security Rules (Section 3): ةرفشم رورم تاملك ، ownership-scoping, input sanitization
- Scalability Rules (Section 4): indexes ةدحم ، pagination support, rate-limiting
- Testing Rules (Section 6): ةلماش isolation tests و لمكت تارابتخا
- Documentation Rule (Section 1): PDF + يبرع ريرقت

تانايبال ةدعاق ي سراهل لواح ةطحال ##

ةرركملا سراهل صوصخب Mongoose تاريذحت حيحصت م

- (email+role, phone+role) ةئازل ةبكركملا سراهل ةلازما
- ةطيسبل تامالعتسالل عرسأو ةيفاك اهنأل ةيدرفل سراهل اب انطفتحا
- لصفأ تانايب ةدعاق ءادأو تاريذحت ال : ةجيتنل